PROYECTO 1 - GESTIÓN, INVESTIGACIÓN Y ESCALAMIENTO DE UN INCIDENTE DE SEGURIDAD

RESPALDO TÉCNICO

→ **Proyecto**: Security Incident Management & Escalation - Orion Financial Group
→ **Organización**: Orion Financial Group (ficticia)
→ **Área**: Security Operations Center (SOC) / Incident Response
→ **Rol simulado**: SOC Analyst L1
→ **Tipo**: Proyecto académico independiente e integrador
→ **Alcance y naturaleza del proyecto:** Proyecto académico independiente basado en un escenario ficticio para aplicar conocimientos del Curso 8 del Certificado de Ciberseguridad de Google, sobre gestión, escalamiento y comunicación de incidentes. Los resultados son simulados y no representan un incidente real. La evidencia real obtenida en el laboratorio de conectividad se presenta por separado. No debe utilizarse como prueba de los acontecimientos ficticios de Orion.

PARTE I - ESCENARIO DE INVESTIGACIÓN

1. Presentación de la organización

Orion Financial Group es una organización ficticia que presta servicios financieros y comerciales a clientes corporativos. En el escenario dispone de cuentas individuales, almacenamiento compartido, recursos internos con permisos diferenciados y mecanismos centralizados de registro.

El SOC realiza el análisis inicial de alertas, documenta hallazgos y escala los casos que requieren investigación o permisos adicionales. SOC L2 / Incident Response profundiza en los casos escalados y coordina las acciones de respuesta correspondientes. Los equipos de infraestructura y los responsables del negocio pueden intervenir según sus funciones.

El analista L1 debe respetar los procedimientos internos y no ejecutar medidas de contención para las que no tenga autorización.

2. Situación inicial

A las 10:12 de un martes laborable, el SIEM simulado genera una alerta relacionada con la cuenta `cfernandez`, asociada al área Comercial. La secuencia descrita contiene cinco intentos fallidos de autenticación entre las 09:54 y las 09:58, seguidos de un inicio de sesión exitoso a las 09:59.

Después se informa de acceso al almacenamiento corporativo a las 10:03, descarga de `clientes_Q3.xlsx` a las 10:06, descarga de `contratos_clientes.zip` a las 10:08 e intento denegado de acceso a `Finance-Shared` a las 10:10. La alerta se genera a las 10:12.

En esta etapa, el escenario no establece de forma concluyente que la cuenta haya sido comprometida ni identifica a la persona que realizó las acciones.

3. Datos iniciales del escenario

La dirección IP forma parte del escenario original. No debe considerarse maliciosa únicamente por aparecer en la alerta. Si se preparan archivos sintéticos para pruebas técnicas, deben identificarse como tales y mantenerse diferenciados de los datos del caso original.

Campo	Información descrita
Cuenta	`cfernandez`
Área	Comercial
IP indicada en el escenario	`185.220.101.44`
Horario habitual informado	09:00-18:00
Período de eventos	09:54-10:12
Fuente de la alerta	SIEM simulado
Patrón principal	Cinco autenticaciones fallidas seguidas de una exitosa
Actividad posterior	Acceso al almacenamiento, dos descargas e intento denegado a `Finance-Shared`
Estado inicial	Pendiente de análisis
Determinación inicial	Posible compromiso de cuenta; no confirmado

4. Secuencia de eventos descrita

Esta tabla organiza la secuencia comunicada para el ejercicio. No sustituye los registros originales ni demuestra por sí sola que todos los eventos fueran realizados por una misma persona o que exista una relación causal entre ellos.

Hora	Evento	Estado de la información
09:54	Autenticación fallida	Descrito en los datos simulados
09:55	Autenticación fallida	Descrito en los datos simulados
09:56	Autenticación fallida	Descrito en los datos simulados
09:57	Autenticación fallida	Descrito en los datos simulados
09:58	Autenticación fallida	Descrito en los datos simulados
09:59	Autenticación exitosa	Descrito en los datos simulados
10:03	Acceso al almacenamiento corporativo	Descrito en el escenario; fuente primaria por validar
10:06	Descarga de `clientes_Q3.xlsx`	Descrita en el escenario; fuente primaria por validar
10:08	Descarga de `contratos_clientes.zip`	Descrita en el escenario; fuente primaria por validar
10:10	Intento denegado sobre `Finance-Shared`	Descrito en el escenario; fuente primaria por validar
10:12	Alerta SIEM	Alerta simulada

5. Contexto adicional del escenario

La información complementaria del caso indica que:

- La IP no aparece en el historial reciente disponible para la cuenta durante el período de referencia.
- El dispositivo no coincide con el endpoint corporativo habitual.
- El servicio involucrado no tenía MFA aplicado.
- La usuaria manifiesta no reconocer la autenticación ni la actividad posterior.
- La cuenta tiene permisos para acceder a los dos archivos descargados.
- La cuenta no está autorizada para acceder a `Finance-Shared`, y el intento aparece como rechazado.

Estos datos son contexto del escenario. No todos proceden del CSV de eventos ni se consideran verificados automáticamente por los scripts. Para una investigación operativa real, cada dato tendría que vincularse con su fuente primaria y su método de validación.

6. Objetivos y límites de la investigación

Los objetivos del ejercicio son:

- Revisar el patrón de autenticación y organizar la secuencia temporal.
- Distinguir los eventos descritos de los datos contextuales.
- Identificar qué información se conoce sobre la IP, el dispositivo, MFA y los permisos.
- Examinar los accesos y las descargas descritos.
- Evaluar el intento denegado sobre `Finance-Shared`.
- Considerar el posible impacto sobre la confidencialidad, integridad y disponibilidad.
- Documentar las cuestiones pendientes y recomendar el escalamiento.
- Proponer medidas de respuesta sujetas a autorización.
- Mantener separados los datos ficticios de Orion y la evidencia real del laboratorio.

Quedan fuera del alcance la intervención en sistemas corporativos reales, el uso de credenciales reales, las pruebas contra terceros y cualquier afirmación de compromiso o exfiltración que no esté respaldada por evidencia suficiente.

PARTE II - MÉTODO Y ANÁLISIS

7. Metodología de Triage

El flujo de análisis se organiza en estas etapas:

- **Validación de la alerta**: identificar la cuenta, el patrón detectado, el período y las fuentes disponibles.
- **Revisión cronológica**: ordenar los eventos y señalar los intervalos entre ellos.
- **Análisis contextual**: considerar la IP, el dispositivo, el método de autenticación, MFA y los permisos, cuando esos datos estén disponibles.
- **Revisión de accesos**: diferenciar el acceso al almacenamiento, las descargas y el intento denegado.

- **Evaluación inicial:** considerar indicadores y consecuencias potenciales sin convertir una hipótesis en un hecho.
- **Documentación**: registrar la fuente, la interpretación y la limitación de cada hallazgo.
- **Escalamiento**: resumir la información relevante para SOC L2 / Incident Response.
- **Respuesta propuesta**: enumerar medidas que el equipo autorizado podría evaluar.

La correlación descrita es una revisión inicial de la secuencia y el contexto del caso. No debe presentarse como correlación avanzada de múltiples sistemas si no se dispone de registros y consultas que demuestren ese trabajo.

8. Herramientas y alcance técnico de los scripts

Se utilizaron tres scripts de Python para analizar los datos ficticios del caso Orion Financial Group, organizar los eventos e identificar indicadores relevantes para la evaluación inicial de riesgos. Los tres scripts se ejecutaron y sus resultados permitieron organizar la información disponible para orientar la investigación.

Archivo	**Función documentada**	**Límite de interpretación**
`analizar_eventos.py`	Resume los eventos de autenticación e identifica patrones relevantes para el análisis inicial.	Los patrones identificados no confirman por sí solos un compromiso de cuenta.
`analizar_eventos_ampliado.py`	Organiza cronológicamente los eventos y resume las categorías de actividad identificadas.	La organización cronológica no demuestra causalidad ni permite determinar por sí sola la identidad de quien realizó la actividad.
`evaluar_riesgos.py`	Genera una matriz inicial de evaluación que contempla autenticaciones fallidas y exitosas, descargas de archivos, accesos denegados y alertas del SIEM. Incluye orientaciones para continuar la investigación.	La matriz orienta la evaluación inicial, pero no confirma por sí sola un compromiso de cuenta ni constituye una puntuación numérica formal del riesgo.

Los resultados del análisis identificaron 11 eventos, incluidos cinco intentos fallidos de autenticación, una autenticación exitosa, un acceso al almacenamiento corporativo, dos descargas de archivos, un intento denegado de acceso y una alerta del SIEM. La salida de `evaluar_riesgos.py` presenta estos indicadores y propone verificaciones adicionales para orientar su investigación.

Los scripts permiten organizar la información e identificar actividades que requieren un análisis adicional. Sin embargo, sus resultados no confirman por sí solos la presencia de malware, la identidad de quien realizó la actividad ni una exfiltración de información. Estas conclusiones requieren evidencia adicional y validación contextual.

El análisis se complementa con la revisión de la cronología, los permisos asociados a los recursos y el contexto de autenticación. Los resultados constituyen una evaluación inicial basada en datos ficticios y respaldan la recomendación de escalar el caso a SOC L2 / Incident Response para continuar la investigación.

9. Análisis mediante las 5 W

What - ¿Qué ocurrió? El escenario describe cinco intentos fallidos de autenticación seguidos de un inicio de sesión exitoso, acceso al almacenamiento corporativo, dos descargas y un intento denegado sobre `Finance-Shared`.

Who - ¿Quién está involucrado? La cuenta es `cfernandez`, asociada al área Comercial. La identidad de la persona que operó la sesión no está determinada.

When - ¿Cuándo ocurrió? Los eventos descritos se extienden desde las 09:54 hasta las 10:12, cuando se genera la alerta simulada.

Where - ¿Dónde ocurrió? La actividad descrita involucra la autenticación de una cuenta corporativa, el almacenamiento compartido y un recurso de Finanzas. La IP indicada es `185.220.101.44`; su presencia no demuestra por sí sola que la conexión fuera maliciosa.

Why - ¿Por qué requiere investigación? La combinación de intentos fallidos, autenticación exitosa, contexto de IP y dispositivo, descargas y actividad que la usuaria no reconoce es compatible con un posible acceso no autorizado. La causa inicial y el método de acceso permanecen sin determinar.

10. Registro de hallazgos

Los hallazgos se clasifican según su fuente y grado de verificación. Los datos descritos en el escenario simulado no constituyen una validación independiente mediante registros de producción. La fuente de cada dato se identifica en la columna «Estado y fuente».

ID	Hallazgo	Interpretación	Estado y fuente
F-01	Cinco intentos fallidos seguidos de un inicio de sesión exitoso	Secuencia que requiere revisión	Descrito en los datos simulados; resumido por scripts básicos
F-02	IP no observada en el historial reciente indicado	Indicador contextual, no prueba de malicia	Contexto del escenario
F-03	Dispositivo distinto del endpoint habitual	Indicador que requiere validación	Contexto del escenario
F-04	Servicio sin MFA aplicado	Debilidad de control que debe evaluarse	Contexto del escenario

F-05	Dos descargas descritas	Actividad relevante para evaluar el alcance	Escenario/datos simulados; fuente primaria por validar
F-06	Intento denegado sobre Finance-Shared	Acceso rechazado según el escenario	Contexto del caso; fuente primaria por validar
F-07	La usuaria no reconoce la actividad	Dato contextual relevante	Declaración descrita en el escenario
F-08	Presencia de malware	No hay evidencia suficiente para confirmarla	No determinado
F-09	Exfiltración de archivos	No hay evidencia suficiente de transferencia externa	No determinada
F-10	Método inicial e identidad del responsable	Requieren investigación adicional	No determinados

11. Evaluación inicial del riesgo y del impacto

La evaluación inicial considera la posibilidad de actividad no autorizada y las consecuencias potenciales sobre la confidencialidad, integridad y disponibilidad de la información.

El escenario describe archivos de naturaleza comercial, de clientes e interna. Por ello, es razonable investigar su acceso y determinar si se produjo actividad adicional. No se asigna una puntuación numérica de riesgo en este informe, ya que los scripts revisados no implementan un cálculo formal de ese tipo.

La descarga de un archivo no equivale automáticamente a exfiltración. Para sostener una conclusión de transferencia externa harían falta registros adicionales pertinentes, por ejemplo telemetría del servicio, registros de red o evidencia de transferencia que pudiera correlacionarse con el período investigado. Una IP desconocida tampoco demuestra por sí sola un compromiso.

Determinación inicial: la combinación de indicadores es consistente con un posible compromiso de cuenta y justifica escalar el caso. No se considera confirmado el compromiso, la presencia de malware ni la exfiltración.

12. Preservación de evidencias y protección de la información

Durante la investigación de un incidente de seguridad, es importante proteger la información sensible y mantener un registro de cómo se obtienen, almacenan y manejan las evidencias.

Para ello, se consideran las siguientes medidas:

- **Acceso limitado a la información (Need-to-Know):** compartir los datos únicamente con las personas que los necesitan para cumplir una función autorizada.
- **Privilegios mínimos (Least Privilege):** otorgar a cada usuario solo los permisos necesarios para realizar sus tareas.

- **Minimización de datos (Data Minimization):** incluir únicamente la información relevante para investigar el incidente, evitando exponer datos personales o información de clientes que no sean necesarios.
- **Uso de canales autorizados:** compartir y almacenar la información mediante los medios aprobados por la organización.
- **Trazabilidad de las evidencias:** documentar cómo se obtiene cada evidencia, quién la maneja, dónde se almacena y qué procedimientos se aplican durante su tratamiento.

Cuando corresponda, cada evidencia debe identificarse y documentarse con información como su identificador, fuente, fecha y hora de adquisición, responsable, ubicación de almacenamiento, procedimiento utilizado y hash criptográfico.

Un **hash criptográfico** es un valor que permite comprobar si el contenido de un archivo coincide con una versión previamente registrada. Sin embargo, por sí solo no demuestra que el archivo provenga de una fuente auténtica ni que se haya obtenido mediante un procedimiento correcto.

En este caso, estas medidas forman parte de las buenas prácticas propuestas para proteger la información y mantener la trazabilidad durante la investigación. Su inclusión en la documentación no implica que todas se hayan aplicado efectivamente en el escenario simulado.

13. Plan de respuesta propuesto

Todas las medidas siguientes son propuestas para el escenario y requieren autorización según los procedimientos aplicables.

La propuesta de contención no demuestra que una medida se haya ejecutado ni que se haya resuelto la causa del incidente.

Medida propuesta	Objetivo	Consideración
Restringir temporalmente la cuenta	Reducir el posible acceso no autorizado	Evaluar el impacto operativo y seguir el procedimiento
Revocar sesiones y tokens	Reducir el uso continuado de sesiones activas	Confirmar qué sesiones deben invalidarse
Restablecer credenciales	Reducir el riesgo de uso de credenciales comprometidas	Utilizar un procedimiento seguro
Habilitar o exigir MFA	Reforzar la autenticación	Revisar cobertura y condiciones del servicio
Preservar registros	Mantener información útil para investigar	Registrar fuentes y tiempos
Revisar actividad posterior	Determinar si la actividad continúa	Correlacionar nuevos eventos
Revisar cuentas relacionadas	Evaluar un posible alcance mayor	Basarse en indicadores disponibles

Examinar permisos	Identificar accesos innecesarios	Comparar permisos con funciones autorizadas

14. Informe de escalamiento SOC L1 → SOC L2 / Incident Response

Asunto: Posible compromiso de cuenta - `cfernandez`

Resumen: El escenario describe cinco intentos fallidos de autenticación, seguidos de un inicio de sesión exitoso. Después se informa de acceso al almacenamiento corporativo, dos descargas y un intento denegado sobre `Finance-Shared`.

Indicadores contextuales: IP no observada en el historial reciente indicado, dispositivo distinto del habitual, servicio sin MFA y declaración de la usuaria de que no reconoce la actividad.

Impacto conocido en el escenario: se describen accesos y descargas de dos archivos mediante una cuenta con permisos para acceder a ellos. El intento sobre `Finance-Shared` figura como rechazado.

Aspectos no determinados: identidad de la persona que operó la sesión, método inicial de acceso, presencia de malware, transferencia externa y alcance total de la posible actividad no autorizada.

Determinación L1: actividad consistente con un posible compromiso de cuenta; no confirmado.

Recomendación: escalar a SOC L2 / Incident Response para validar fuentes primarias, ampliar el análisis de autenticación y sesiones, revisar el alcance de los accesos y evaluar la posible exposición de información. Preservar los registros disponibles y aplicar únicamente las medidas autorizadas.

Este informe es una pieza de comunicación simulada; no acredita que el caso se haya escalado en una organización real.

15. Comunicación a partes interesadas

15.1. Comunicación técnica

La comunicación para SOC L2 debe contener la cronología, los indicadores, las fuentes disponibles, las limitaciones, los aspectos pendientes y las acciones recomendadas. Debe diferenciar entre los datos del escenario y las comprobaciones efectivamente realizadas.

15.2. Comunicación ejecutiva

Ejemplo de comunicación simulada: Se identificó actividad no reconocida asociada con una cuenta corporativa. El escenario incluye intentos fallidos de autenticación, un inicio de sesión exitoso, acceso al almacenamiento y descarga de documentos, además de un intento denegado de acceso a otro recurso interno. Se recomienda continuar la investigación mediante

el equipo responsable. Por el momento, la información disponible no permite confirmar una transferencia externa de datos ni determinar quién realizó la actividad.

La comunicación ejecutiva prioriza la situación, el impacto potencial y la decisión requerida; la técnica incorpora los detalles necesarios para continuar la investigación.

16. Seguimiento, recuperación y mejora continua

Después del escalamiento, el equipo responsable podría revisar registros de autenticación, sesiones, dispositivos, permisos, accesos a archivos y actividad relacionada.

Si se confirmara un uso no autorizado, la recuperación podría incluir restablecimiento de credenciales, revocación de sesiones, revisión de permisos, aplicación de MFA y monitorización posterior. Antes de cerrar un caso real, deberían verificarse los criterios de cierre, la documentación de las acciones y el alcance conocido.

El escenario no confirma que esas acciones se hayan ejecutado ni que una cuenta haya sido recuperada.

Áreas de mejora que podrían evaluarse: cobertura de MFA; detección de accesos desde IP o dispositivos inusuales; correlación de autenticaciones y actividad sobre archivos; revisión de permisos; disponibilidad y conservación de registros; criterios de escalamiento; calidad de documentación y comunicación; y efectividad del playbook de respuesta. Son oportunidades de revisión, no defectos confirmados de una organización real.

17. Conclusión técnica

El escenario ficticio de Orion Financial Group permitió estructurar un proceso de triage y documentación de una alerta asociada con un posible compromiso de cuenta desde la perspectiva de SOC L1. La secuencia de eventos y el contexto descrito justifican recomendar el escalamiento a SOC L2 / Incident Response.

La conclusión se mantiene dentro de los límites de la información disponible: no se confirma el compromiso de cuenta, malware, identidad del responsable ni exfiltración. El valor formativo del ejercicio consiste en organizar los datos, documentar las limitaciones, formular recomendaciones razonadas y evitar conclusiones que excedan la evidencia.

PARTE III - EVIDENCIA REAL DEL LABORATORIO

ANEXO A. Prueba de conectividad ICMP

Identificador recomendado: EV-01.

Archivo PCAPNG: evidencias/reales/Proyecto08B_Fase01_Conectividad_ICMP.pcapng

Captura de pantalla: Fasi 01_conectividad_Captura de pantalla_.png

Se conserva la grafía indicada para coincidir con el nombre real previamente identificado.

Esta evidencia corresponde a una prueba real de laboratorio entre Kali Linux (192.168.56.101) y Metasploitable 2 (192.168.56.102) en la red Host-Only 192.168.56.0/24. La captura descrita contiene ocho paquetes ICMP -cuatro Echo Request y cuatro Echo Reply- y cuatro paquetes ARP relacionados con la resolución de direcciones. La prueba de ping informó cuatro paquetes enviados, cuatro recibidos y cero pérdida.

La evidencia respalda únicamente la conectividad observada entre esas máquinas virtuales durante la prueba. No demuestra acceso a Internet, vulnerabilidades, actividad maliciosa, compromiso de cuenta ni acontecimientos del escenario Orion.

ANEXO B. Inventario de archivos del proyecto

Archivo	**Función prevista**
datos/eventos_orion_simulados.csv	Datos sintéticos del escenario Orion
analizar_eventos.py	Resumen de eventos de autenticación
analizar_eventos_ampliado.py	Organización cronológica y resumen de eventos
evaluar_riesgos.py	Indicadores para orientar la evaluación; no atribuir puntuación formal sin implementación
hallazgos_iniciales.csv	Registro de hallazgos del caso simulado
informe_escalamiento_soc_l1_l2.md	Documento de escalamiento simulado
plan_respuesta_incidente.md	Medidas propuestas de respuesta
actualizacion_incidente.md	Actualizaciones del caso simulado
inventario_evidencias.csv	Identificación de evidencias y

	hashes registrados
evidencias/reales/Proyecto08B_Fase01_Conectividad_ICMP.pcapng	Captura real de tráfico del laboratorio
Fasi 01_conectividad_Captura de pantalla_.png	Captura visual de la prueba ICMP

ANEXO C. Inventario previsto de evidencias del escenario

Este inventario representa las fuentes que serían útiles para una investigación completa; no afirma que todas estén disponibles en el material actual.

ID	Evidencia prevista	Propósito y estado
E-01	Registros de autenticación	Validar intentos fallidos y autenticación exitosa; eventos descritos en datos simulados
E-02	Registros de acceso a recursos	Investigar almacenamiento y archivos; fuente primaria por validar
E-03	Registros de autorización	Verificar el rechazo de Finance-Shared; fuente primaria por validar
E-04	Contexto de usuario y dispositivo	Comparar con actividad habitual; contexto descrito, fuente primaria por validar
E-05	Captura de red relacionada con Orion	No se afirma que exista una captura de Orion; no confundir con la captura ICMP real del laboratorio
E-06	Resultados de Python/SQL	Conservar únicamente resultados realmente generados
E-07	Línea temporal consolidada	Reconstrucción basada en la secuencia simulada
E-08	Manifiesto de evidencias y hashes	Verificar contra los archivos actuales

ANEXO D. Criterios de documentación y presentación

Para mantener la trazabilidad del análisis, se distinguen las siguientes categorías:

Hecho registrado en el escenario: dato incluido en los registros simulados.

Contexto del escenario: información complementaria que no necesariamente procede del CSV.

Interpretación: significado posible de uno o varios datos.

Hipótesis: explicación que necesita validación.

No determinado: cuestión para la que no hay evidencia suficiente.

Acción propuesta: medida recomendada que no se presenta como ejecutada.